SK Shieldus Rookies

상세 진단 보고서 (실무진용)

모의 교육 플랫폼 취약점 진단 결과

러닝브릿지(가상) 온라인 교육 플랫폼

문서 번호	SCAN-20261007-001-T	**진단 일자**	2026-10-07
진단 대상	웹 서비스 (localhost:5000)	**작성일**	2026-10-07
작성	SK쉴더스 루키즈 34기 1석삼조 팀	**대상 독자**	정보보호·개발·운영 담당자

본 보고서는 SK쉴더스 루키즈 교육과정의 프로젝트 산출물이며, SK쉴더스의 공식 진단 보고서가 아닙니다.

1. 진단 개요

1.1 대상 및 범위

자산	자산 ID	개인정보 처리	점검 항목
웹 서비스 (localhost:5000)	LOCALHOST-5000	처리	19개

1.2 적용 기준

구분	문서	버전	시행일
법률	개인정보 보호법	법률 제21445호	2026-09-11
고시	개인정보의 안전성 확보조치 기준	개인정보보호위원회고시 제2026-9호	2026-07-01
인증기준	ISMS-P 인증기준 안내서	2023.11	-

1.3 법령·인증기준 매핑 방식

취약점과 법령·ISMS-P 인증기준의 매핑은 llm+rule으로 수행했습니다 (모델 gpt-4.1-mini, 프롬프트 v4/n3). 담당자 검토를 마친 매핑은 `검토 완료`, 아직 확인하지 않은 매핑은 `검토 전`으로 표시합니다. 현재 검토 전 매핑은 24건입니다.

2. 진단 결과 요약

점검 19개 항목 중 취약 7개, 양호 12개입니다. 전체 위험 수준은 **심각**(개인정보를 처리하는 자산에 '상' 위험 취약점이 있음)으로 판정했습니다.

2.1 위험도별 현황

위험도	취약 항목
상	7개
중	0개
하	0개

2.2 항목별 결과

항목	점검 항목	대상 자산	위험도	결과
IL-COMMENT-01	주석 내 정보 누출	웹 서비스 (localhost:5000)	상	취약
W-01	유추 가능한 비밀번호	웹 서비스 (localhost:5000)	상	취약
W-02	낮은 복잡도의 비밀번호 정책	웹 서비스 (localhost:5000)	상	취약
AUTH-01	불충분한 인증 절차	웹 서비스 (localhost:5000)	상	취약
W-05	타인 문의글 열람	웹 서비스 (localhost:5000)	상	취약
W-06	타인 문의글 댓글 작성	웹 서비스 (localhost:5000)	상	취약
PWRECOVERY-01	취약한 비밀번호 복구 절차	웹 서비스 (localhost:5000)	상	취약
IL-COMMENT-02	주석 내 정보 누출	웹 서비스 (localhost:5000)	하	양호
IL-COMMENT-03	주석 내 정보 누출	웹 서비스 (localhost:5000)	하	양호
IL-COMMENT-04	주석 내 정보 누출	웹 서비스 (localhost:5000)	하	양호
IL-COMMENT-05	주석 내 정보 누출	웹 서비스 (localhost:5000)	하	양호
IL-COMMENT-06	주석 내 정보 누출	웹 서비스 (localhost:5000)	하	양호
IL-COMMENT-07	주석 내 정보 누출	웹 서비스 (localhost:5000)	하	양호
IL-COMMENT-08	주석 내 정보 누출	웹 서비스 (localhost:5000)	하	양호
IL-COMMENT-09	주석 내 정보 누출	웹 서비스 (localhost:5000)	하	양호
IL-MASKING-01	중요 정보 마스킹 미흡	웹 서비스 (localhost:5000)	하	양호

항목	점검 항목	대상 자산	위험도	결과
IL-MASKING-02	중요 정보 마스킹 미흡	웹 서비스 (localhost:5000)	하	양호
W-03	비인증 접근	웹 서비스 (localhost:5000)	하	양호
W-04	수직 권한 상승	웹 서비스 (localhost:5000)	하	양호

3. 취약점 상세

3.1 주석 내 정보 누출 (IL-COMMENT-01) 상

식별 번호	SCAN-20261007-001-IL-COMMENT-01-LOCALHOST-5000
대상 자산	웹 서비스 (localhost:5000) (LOCALHOST-5000), 개인정보 처리
설명	로그인 경로에서 주석 내에 계정 정보와 시스템 파악에 사용될 수 있는 디버그 정보가 노출되어 있습니다. 이는 공격자가 시스템 구조를 파악하고 공격에 이용할 수 있는 정보를 제공할 수 있습니다.
영향	공격자가 시스템 구조를 파악하여 추가적인 공격을 계획할 수 있으며, 계정 정보가 노출되어 계정 탈취 위험이 있습니다.
현황	http://localhost:5000/login 경로에서 주석 내 정보 누출 확인. 계정정보, 시스템 파악에 사용될 수 있는 디버그 정보 등이 주석에 존재 확인된 정보: comment; types
판단 기준	양호: 중요 정보가 마스킹 처리되어 있으며, 서비스 운영 및 서버 사이드의 구조를 파악할 수 있는 불필요한 정보가 노출되지 않는 경우 / 취약: 중요 정보가 평문으로 노출되거나, 서비스 운영 및 서버 사이드의 구조를 파악할 수 있는 과도한 정보가 노출되는 경우
조치 방법	중요 정보를 마스킹 처리하고, 샘플 페이지나 불필요한 정보를 제공하는 요소를 삭제하여 과도한 정보 노출을 최소화함으로써 민감 정보와 내부 시스템 구조의 노출을 방지함
관련 법령	매핑된 법령 없음
ISMS-P	**2.10.3 공개서버 보안** 검토 전 매핑 근거: 웹 서비스의 주석 내에 계정정보 및 시스템 파악에 사용될 수 있는 디버그 정보가 노출되어 공개서버 보안 요구사항을 미충족함.
매핑 검토 메모	선택된 기준에 [관련 법규]가 없어 조문을 비움 (팀 합의: LLM으로 채우지 않음)

3.2 유추 가능한 비밀번호 (W-01) 상

식별 번호	SCAN-20261007-001-W-01-LOCALHOST-5000
대상 자산	웹 서비스 (localhost:5000) (LOCALHOST-5000), 개인정보 처리
설명	로그인 경로에서 유추 가능한 비밀번호가 사용되고 있습니다. 이는 공격자가 쉽게 비밀번호를 추측하여 계정에 접근할 수 있는 위험을 초래합니다.
영향	공격자가 계정에 무단으로 접근하여 개인정보를 유출하거나 시스템을 악용할 수 있습니다.
현황	http://localhost:5000/login 경로에서 유추 가능한 비밀번호 확인. 관리자 및 사용자 계정의 비밀번호가 유추하기 쉬운 값으로 설정되어 있음 확인된 정보: id:student1 password:student123

판단 기준	항목 카탈로그에 기준이 없습니다.
조치 방법	항목 카탈로그에 조치 방법이 없습니다.
관련 법령	**개인정보 보호법 제29조(안전조치의무)** 검토 전 제29조(안전조치의무) 개인정보처리자는 개인정보가 유출등이 되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다. 매핑 근거: 유추 가능한 비밀번호 사용은 개인정보의 안전성 확보를 위한 기술적 조치 미흡으로 개인정보 보호법 제29조(안전조치의무)에 해당한다. (근거: ISMS-P 2.5.4(비밀번호 관리) 관련 법규) **개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리)** 검토 전 ⑤ 개인정보처리자는 개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하여야 한다. 매핑 근거: 유추 가능한 비밀번호 사용은 인증수단을 안전하게 적용·관리하지 않은 것으로 개인정보의 안전성 확보조치 기준 제5조 제5항에 해당한다. (근거: ISMS-P 2.5.4(비밀번호 관리) 관련 법규)
ISMS-P	**2.5.4 비밀번호 관리** 검토 전 매핑 근거: 관리자 및 사용자 계정의 비밀번호가 유추하기 쉬운 값으로 설정되어 있어 안전한 비밀번호 관리절차 및 작성규칙을 미이행함.

3.3 낮은 복잡도의 비밀번호 정책 (W-02) 상

식별 번호	SCAN-20261007-001-W-02-LOCALHOST-5000
대상 자산	웹 서비스 (localhost:5000) (LOCALHOST-5000), 개인정보 처리
설명	회원가입 경로에서 낮은 복잡도의 비밀번호가 허용되고 있습니다. 이는 비밀번호 추측 공격에 취약하게 만듭니다.
영향	공격자가 쉽게 비밀번호를 추측하여 계정에 접근할 수 있으며, 개인정보 유출 위험이 증가합니다.
현황	http://localhost:5000/register 경로에서 낮은 복잡도의 비밀번호 정책 확인. 1234와 같은 간단한 비밀번호로 회원가입 가능 확인된 정보: [{'username': 'testuserbf23', 'password': '1234'}]
판단 기준	항목 카탈로그에 기준이 없습니다.
조치 방법	항목 카탈로그에 조치 방법이 없습니다.

관련 법령	**개인정보 보호법 제29조(안전조치의무)** 검토 전 제29조(안전조치의무) 개인정보처리자는 개인정보가 유출등이 되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다. 매핑 근거: 낮은 복잡도의 비밀번호 정책으로 인해 인증수단의 안전한 관리가 이루어지지 않아 개인정보의 안전성 확보조치 의무에 위배된다. (근거: ISMS-P 2.5.4(비밀번호 관리) 관련 법규) **개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리)** 검토 전 ⑤ 개인정보처리자는 개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하여야 한다. 매핑 근거: 간단한 비밀번호(예: 1234)로 회원가입이 가능하여 인증수단을 안전하게 적용·관리하지 않은 점이 제5항(인증수단의 안전한 적용 및 관리)에 위배된다. (근거: ISMS-P 2.5.4(비밀번호 관리) 관련 법규)
ISMS-P	**2.5.4 비밀번호 관리** 검토 전 매핑 근거: 진단 근거에 따르면 1234와 같은 간단한 비밀번호가 허용되어 비밀번호 복잡도 제한이 없어 ISMS-P 2.5.4 비밀번호 관리 기준을 미충족함.

3.4 불충분한 인증 절차 (AUTH-01) 상

식별 번호	SCAN-20261007-001-AUTH-01-LOCALHOST-5000
대상 자산	웹 서비스 (localhost:5000) (LOCALHOST-5000), 개인정보 처리
설명	학생 프로필 경로에서 재인증 없이 전화번호 변경이 가능합니다. 이는 공격자가 임의로 개인정보를 변경할 수 있는 취약점을 제공합니다.
영향	공격자가 회원의 개인정보를 임의로 변경하여 신뢰성을 훼손할 수 있으며, 개인정보 유출 위험이 있습니다.
현황	/student/profile 경로에서 불충분한 인증 절차 확인. 현재 비밀번호나 OTP 등 재인증 정보를 전송하지 않았는데도 서버에서 전화번호 변경이 실제 반영되었습니다. 확인된 정보: 로그인 및 인증 페이지 접근 성공 (HTTP 302 -> 302 -> 200, 최종 URL http://localhost:5000/student; HTTP 200, 최종 URL h; 기존 개인정보(name, birth_date, phone) 수집 성공 (HTTP 200, 최종 URL http://localhost:5000/student/profile); 재인증 값을 제공하지 않은 개인정보 변경 요청: HTTP 302 -> 200, 최종 URL http://localhost:5000/student/mypage, 폼의 재인증 필드=없; 변경 후 재조회 결과: 전화번호 변경=확인, 이름/생년월일 유지=확인; 원본 개인정보 복구/유지 성공 (HTTP 302 -> 200, 최종 URL http://localhost:5000/student/mypage)
판단 기준	양호: 중요 정보 페이지 접근 시 추가 인증 절차가 존재하며, 인증 로직이 서버 사이드에서 구현되어 우회가 불가능한 경우 / 취약: 중요 정보 페이지 접근 시 추가 인증 절차가 존재하지 않거나, 인증 로직 우회가 가능하여 비인가자가 접근 가능할 경우
조치 방법	중요 페이지에 대한 추가 인증 절차를 도입하고, 서버 사이드에서 인증 여부를 검증하는 로직 구현

관련 법령	**개인정보 보호법 제29조(안전조치의무)** 검토 전 제29조(안전조치의무) 개인정보처리자는 개인정보가 유출등이 되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다. 매핑 근거: 재인증 없이 전화번호 변경이 가능하여 개인정보의 안전성 확보를 위한 기술적·관리적 조치가 미흡함을 보여준다. (근거: ISMS-P 2.5.3(사용자 인증) 관련 법규) **개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리)** 검토 전 ⑤ 개인정보처리자는 개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하여야 한다. 매핑 근거: 재인증 절차 없이 개인정보 변경이 가능하여 인증수단을 안전하게 적용·관리하지 않은 점이 제5항에 해당한다. (근거: ISMS-P 2.5.3(사용자 인증) 관련 법규) **개인정보의 안전성 확보조치 기준 제6조 제2항(접근통제)** 검토 전 ② 개인정보처리자는 개인정보처리시스템에 대한 정당한 접근 권한을 가진 자(다만, 정보주체는 제외한다)가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하여야 한다. 다만, 이용자가 아닌 정보주체의 개인정보를 처리하는 개인정보처리시스템의 경우 가상사설망 등 안전한 접속수단 또는 안전한 인증수단을 적용할 수 있다. 매핑 근거: 외부에서 개인정보처리시스템에 접속하여 재인증 없이 개인정보 변경이 가능하므로 안전한 인증수단을 적용하지 않은 제2항에 해당한다. (근거: ISMS-P 2.5.3(사용자 인증) 관련 법규)
ISMS-P	**2.5.3 사용자 인증** 검토 전 매핑 근거: 재인증 절차 없이 전화번호 변경이 가능하여 안전한 사용자 인증 절차를 적용하지 않아 정보시스템과 개인정보에 대한 접근 통제가 미흡함.

3.5 타인 문의글 열람 (W-05) 상

식별 번호	SCAN-20261007-001-W-05-LOCALHOST-5000
대상 자산	웹 서비스 (localhost:5000) (LOCALHOST-5000), 개인정보 처리
설명	문의글 경로에서 타인의 문의글을 열람할 수 있습니다. 이는 권한 없는 사용자가 다른 사용자의 개인정보에 접근할 수 있는 취약점을 제공합니다.
영향	개인정보가 권한 없는 사용자에게 노출되어 프라이버시 침해 및 정보 유출 위험이 있습니다.
현황	/inquiries/QST-000001 경로에서 타인 문의글 열람 확인. 작성자(A) GET /inquiries/QST-000001: HTTP 200 / 다른 학생(B) GET /inquiries/QST-000001: HTTP 200 / B의 응답에 A의 문의글 내용 포함: 예 / 문의글 식별자 QST-000001는 일련번호 형식이라 다른 글의 ID도 추측 가능 확인된 정보: 작성자(A) GET /inquiries/QST-000001: HTTP 200; 다른 학생(B) GET /inquiries/QST-000001: HTTP 200; B의 응답에 A의 문의글 내용 포함: 예; 문의글 식별자 QST-000001는 일련번호 형식이라 다른 글의 ID도 추측 가능
판단 기준	항목 카탈로그에 기준이 없습니다.
조치 방법	항목 카탈로그에 조치 방법이 없습니다.

관련 법령	**개인정보 보호법 제29조(안전조치의무)** 검토 전 제29조(안전조치의무) 개인정보처리자는 개인정보가 유출등이 되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다. 매핑 근거: 타인 문의글 열람으로 개인정보가 권한 없는 자에게 노출되어 안전성 확보 조치 의무에 위배됨. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규) **개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리)** 검토 전 ① 개인정보처리자는 개인정보처리시스템에 대한 접근 권한을 업무 수행에 필요한 최소한의 범위로 차등 부여하여야 한다. 매핑 근거: 타인 문의글 열람이 가능하다는 것은 업무 수행에 필요한 최소한의 범위로 접근 권한을 차등 부여하지 않은 것으로 판단됨. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규) **개인정보의 안전성 확보조치 기준 제6조 제2항(접근통제)** 검토 전 ③ 개인정보처리자는 처리하는 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치를 하여야 한다. 매핑 근거: 권한 없는 자가 타인 문의글을 열람할 수 있어 개인정보가 공개·유출된 상태임. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규)
ISMS-P	**2.6.3 응용프로그램 접근** 검토 전 매핑 근거: 타인 문의글이 URL 파라미터 변조로 열람 가능하여 응용프로그램 접근권한 제한 및 중요정보 노출 최소화 기준을 미충족함. **3.2.1 개인정보 현황관리** 검토 전 매핑 근거: 타인 개인정보가 노출되어 개인정보 항목 및 처리 현황 관리 기준을 미충족함.
매핑 검토 메모	LLM 항 판단으로 제외한 조문: SAFE-12 제12조(출력 · 복사시 안전조치): 진단 근거는 출력·복사와 관련된 내용이 아니므로 해당하지 않음. / PIPA-32 제32조(개인정보파일의 등록 및 공개): 진단 근거는 개인정보파일 등록 및 공개와 관련된 내용이 아니므로 해당하지 않음.

3.6 타인 문의글 댓글 작성 (W-06) 상

식별 번호	SCAN-20261007-001-W-06-LOCALHOST-5000
대상 자산	웹 서비스 (localhost:5000) (LOCALHOST-5000), 개인정보 처리
설명	문의글 댓글 경로에서 타인의 문의글에 댓글을 작성할 수 있습니다. 이는 권한 없는 사용자가 다른 사용자의 개인정보에 접근할 수 있는 취약점을 제공합니다.
영향	개인정보가 권한 없는 사용자에게 노출되어 프라이버시 침해 및 정보 유출 위험이 있습니다.
현황	/inquiries/QST-000001/comment 경로에서 타인 문의글 댓글 작성 확인. 다른 학생(B) POST /inquiries/QST-000001/comment: HTTP 302 → /inquiries/QST-000001 / 작성자(A) 화면에 B의 댓글 표시: 예 확인된 정보: 다른 학생(B) POST /inquiries/QST-000001/comment: HTTP 302 → /inquiries/QST-000001; 작성자(A) 화면에 B의 댓글 표시: 예

판단 기준	항목 카탈로그에 기준이 없습니다.
조치 방법	항목 카탈로그에 조치 방법이 없습니다.
관련 법령	**개인정보 보호법 제29조(안전조치의무)** 검토 전 제29조(안전조치의무) 개인정보처리자는 개인정보가 유출등이 되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다. 매핑 근거: 타인 문의글 댓글 작성으로 권한 없는 자가 개인정보에 접근한 것은 개인정보 유출 방지를 위한 안전성 확보 조치 의무에 위배된다. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규) **개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리)** 검토 전 ① 개인정보처리자는 개인정보처리시스템에 대한 접근 권한을 업무 수행에 필요한 최소한의 범위로 차등 부여하여야 한다. 매핑 근거: 타인 문의글 댓글 작성이 가능하다는 것은 업무 수행에 필요한 최소한의 범위를 초과하여 접근 권한이 부여된 것으로, 접근 권한의 최소화 의무에 위배된다. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규) **개인정보의 안전성 확보조치 기준 제6조 제2항(접근통제)** 검토 전 ③ 개인정보처리자는 처리하는 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치를 하여야 한다. 매핑 근거: 권한 없는 자가 타인 문의글에 댓글을 작성할 수 있어 개인정보가 권한 없는 자에게 공개되거나 유출된 것으로, 개인정보 처리 시스템에 조치를 하지 않은 것이다. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규)
ISMS-P	**2.6.3 응용프로그램 접근** 검토 전 매핑 근거: 타인 문의글에 댓글을 작성할 수 있어 응용프로그램 접근권한 제한 및 중요정보 노출 최소화 기준을 미충족함.
매핑 검토 메모	LLM 항 판단으로 제외한 조문: SAFE-12 제12조(출력 · 복사시 안전조치): 진단 근거에 개인정보 출력 항목 최소화와 관련된 내용이 없으므로 해당하지 않는다.

3.7 취약한 비밀번호 복구 절차 (PWRECOVERY-01) 상

식별 번호	SCAN-20261007-001-PWRECOVERY-01-LOCALHOST-5000
대상 자산	웹 서비스 (localhost:5000) (LOCALHOST-5000), 개인정보 처리
설명	비밀번호 복구 경로에서 임시 비밀번호가 평문으로 노출되고 있습니다. 이는 비인가자가 쉽게 계정에 접근할 수 있는 취약점을 제공합니다.
영향	비인가자가 계정에 접근하여 개인정보를 유출하거나 시스템을 악용할 수 있습니다.
현황	http://localhost:5000/find_password 경로에서 취약한 비밀번호 복구 절차 확인. 임시 비밀번호가 평문으로 화면에 노출되어 있으며, 고정된 패턴을 가진 형태로 재설정되고 있음. 확인된 정보: 비밀번호 찾기임시 비밀번호:temp1234!로그인하러 가기; 임시 비밀번호:temp1234!

판단 기준	양호: 비밀번호 재설정 시 난수를 이용하여, 인증된 사용자 메일이나 SMS로 임시 비밀번호 또는 비밀번호 재설정을 위한 링크가 전송될 경우 / 취약: 비밀번호 재설정 시 일정 패턴으로 재설정되고 웹 사이트 화면에 바로 출력될 경우
조치 방법	비밀번호 복구 로직을 강화하고, 인증된 사용자 메일이나 SMS에서만 재설정된 비밀번호를 확인할 수 있도록 하여 비인가자가 비밀번호를 획득하지 못하도록 조치
관련 법령	**개인정보 보호법 제29조(안전조치의무)** 검토 전 제29조(안전조치의무) 개인정보처리자는 개인정보가 유출등이 되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다. 매핑 근거: 임시 비밀번호가 평문으로 화면에 노출되고 고정된 패턴으로 재설정되는 것은 개인정보의 안전성 확보를 위한 기술적 조치가 미흡한 것으로 개인정보 보호법 제29조의 안전조치 의무에 위배된다. (근거: ISMS-P 2.5.4(비밀번호 관리), 2.5.3(사용자 인증) 관련 법규) **개인정보의 안전성 확보조치 기준 제6조 제2항(접근통제)** 검토 전 ⑤ 개인정보처리자는 업무용 모바일 기기의 분실 · 도난 등으로 개인정보가 유출되지 않도록 해당 모바일 기기에 비밀번호 설정 등의 보호조치를 하여야 한다. 매핑 근거: 임시 비밀번호가 평문으로 노출되는 것은 업무용 모바일 기기 등의 비밀번호 설정 등 보호조치 미흡과 유사한 개인정보 유출 위험을 내포하므로, 안전성 확보조치 기준 제6조 제5항의 보호조치 의무에 해당한다. (근거: ISMS-P 2.5.3(사용자 인증) 관련 법규)
ISMS-P	**2.5.4 비밀번호 관리** 검토 전 매핑 근거: 임시 비밀번호가 평문으로 화면에 노출되어 비밀번호 관리 절차 및 작성규칙을 위반함. **2.5.3 사용자 인증** 검토 전 매핑 근거: 비밀번호 복구 절차가 안전한 인증절차를 적용하지 않고 있어 사용자 인증이 취약함.
매핑 검토 메모	LLM 항 판단으로 제외한 조문: SAFE-5 제5조(접근 권한의 관리): 진단 근거는 비밀번호 복구 절차의 취약성에 관한 내용으로, 접근 권한의 관리에 관한 조문과 직접적인 관련이 없다.

4. 부록

4.1 기준 문서 원본

ID	원본 파일
PIPA-21445	개인정보 보호법(법률)(제21445호)(20260911).txt
SAFE-2026-9	개인정보의 안전성 확보조치 기준(고시)(제2026-9호)(20260701).txt
ISMSP-2023.11	ISMS-P 인증기준 안내서(2023.11).txt

4.2 보고서 생성 방식

결과 판정(위험도, 취약·양호, 전체 위험 수준)은 진단 데이터와 정해진 규칙으로 산출했습니다. 설명과 영향 문장은 AI가 작성했으며, 판단 기준과 조치 방법은 항목 카탈로그에서, 법령 조문은 기준 문서 원문에서 그대로 가져왔습니다.

유사 사례는 개인정보보호위원회 처분 보도자료 원문으로 확인한 사례 카드에서 검색했고, 과징금 노출액과 조치 우선순위는 아래 기준으로 코드가 계산했습니다. 금액은 AI를 거치지 않았습니다.

4.3 과징금 노출 산정

항목	값	근거·설명
법정 상한	1억 5,000만 원	전체 매출액에서 위반과 무관한 매출을 뺀 금액의 3%. 개인정보 보호법 제64조의2(과징금의 부과), 2026-09-11 시행 개정법
10% 특례 시나리오	5억 원	고의·중과실로 3년 내 같은 유형 반복 위반: 해당 없음 (고객사 프로필의 3년 내 위반 이력 기준. 고의·중과실 여부는 도구가 판단하지 않음) 고의·중과실로 피해 1천만 명 이상: 해당 없음 (정보주체 120,000명 → 1천만 명 기준 미달) 시정명령 불이행으로 유출: 해당 없음 (고객사 프로필의 시정명령 미이행 여부 기준)
투자 감경	최대 40%	보호 투자·보호체계 운영·추가 안전조치를 고려해 기준금액의 최대 40% 감경. 위반 전 3개 사업연도 노력을 보며 고의·중과실 위반은 제외. 상한 기준 예시 9,000만 원
ISMS-P 인증 감경	최대 30%	현재 미인증. ISMS-P 인증에 따른 감경 상한은 최대 30%(개정 전 50%). 중요 개인정보처리자 대상 인증 의무화는 2027-07-01 시행 예정

항목	값	근거·설명
유사 처분 사례 과징금	15건	최소 329만 원, 중앙값 5억 300만 원, 최대 4,235억 7,500만 원. 참고 사례를 뺀 등급(동일 결함·같은 유형·관련 통제)의 처분 사례 중 과징금이 있는 것만 집계. 사례 기업과 고객사의 매출 규모가 달라 예상 부과액이 아니라 '유사 사례에서 실제로 나온 금액'임 유사 사례 중앙값이 이 고객사의 법정 상한보다 큼. 사례 기업이 더 커서 생긴 차이이므로 사례 금액을 고객사 예상 과징금처럼 쓰면 안 됨 (상한을 넘는 과징금은 불가능)

4.4 조치 우선순위

순위	점검 항목	위험도	사례 근거	점수	여기까지 조치 시
1	주석 내 정보 누출	상	동일 결함	4.5	리스크 15.8% 감소
2	불충분한 인증 절차	상	동일 결함	4.5	리스크 31.6% 감소
3	취약한 비밀번호 복구 절차	상	동일 결함	4.5	리스크 47.4% 감소
4	유추 가능한 비밀번호	상	관련 통제	3.75	리스크 60.5% 감소
5	낮은 복잡도의 비밀번호 정책	상	관련 통제	3.75	리스크 73.7% 감소
6	타인 문의글 열람	상	관련 통제	3.75	리스크 86.8% 감소
7	타인 문의글 댓글 작성	상	관련 통제	3.75	리스크 100.0% 감소

점수 = 심각도(상3·중2·하1) × 개인정보 자산(예 1.0·아니오 0.3) × (1 + 0.5 × 사례 근거(동일 결함 1.0·같은 유형 0.7·관련 통제 0.5·참고 0.3·없음 0.2)). 점수는 조치 순서를 정하기 위한 상대값이며 금액이 아닙니다.

4.5 산정 가정과 제외 항목

- 고객사 프로필(매출·정보주체 수 등)은 모의 교육 플랫폼 가정값
- 법정 상한은 최대치이며 예상 부과액이 아님
- 같은 조항에 걸린 취약점이 여러 개여도 법정 상한은 한 번만 적용
- 유사 사례 금액은 대부분 개정법 시행(2026-09-11) 이전 구법 기준 처분
- 투자 감경 예시값은 법정 상한에 최대 감경률을 적용한 것으로, 실제 감경은 기준금액에 적용됨
- 우선순위 점수는 조치 순서를 정하기 위한 상대 점수이며 금액이 아님

제외 항목	사유
주석 내 정보 누출	관련 법 조항이 없어 법적 노출액에서 제외 (ISMS-P 심사 리스크로만 다룸)
주석 내 정보 누출	상태가 '양호'라 노출액 계산에서 제외
주석 내 정보 누출	상태가 '양호'라 노출액 계산에서 제외

제외 항목	사유
주석 내 정보 누출	상태가 '양호'라 노출액 계산에서 제외
주석 내 정보 누출	상태가 '양호'라 노출액 계산에서 제외
주석 내 정보 누출	상태가 '양호'라 노출액 계산에서 제외
주석 내 정보 누출	상태가 '양호'라 노출액 계산에서 제외
주석 내 정보 누출	상태가 '양호'라 노출액 계산에서 제외
주석 내 정보 누출	상태가 '양호'라 노출액 계산에서 제외
중요 정보 마스킹 미흡	상태가 '양호'라 노출액 계산에서 제외
중요 정보 마스킹 미흡	상태가 '양호'라 노출액 계산에서 제외
비인증 접근	상태가 '양호'라 노출액 계산에서 제외
수직 권한 상승	상태가 '양호'라 노출액 계산에서 제외